Botium Toys - Internal Security Audit Report

Google Cybersecurity Certificate - Manage Security Risks | NIST CSF Audit

Auditor: Adedeji David Adegboyega | Date: November 2, 2026

1. Executive Summary

Botium Toys is a small U.S. toy company with a single physical location but a growing global online presence. The IT manager initiated an internal audit to evaluate security posture, identify risks to critical assets, and ensure compliance with PCI DSS (online payments) and GDPR (E.U. business). The audit was conducted using NIST CSF. Findings show 9 of 14 controls failing and non-compliance with PCI DSS, partial compliance with GDPR and SOC. Immediate remediation is required to avoid fines, payment processing loss, and breach risk.

2. Scope and Goals

Scope: User permissions and implemented controls in accounting, endpoint detection, firewalls, IDS, SIEM.
Goals: Adhere to NIST CSF, establish compliance process, fortify controls, implement least privilege and separation of duties, ensure PCI DSS and GDPR compliance.

3. Risk Assessment - Critical Assets & Risks

Asset	Risk	Level
Customer data / PII/SPII	All employees have access, no encryption	High
Financial / Card data	No secure storage, no encryption, violates PCI DSS	High
Legacy systems	No regular maintenance schedule	Medium
Business continuity	No DR plan, no backups	High
Physical location	Locks, CCTV, Fire detection in place	Low

4. Controls Assessment Checklist

Control	Yes/No	Notes
Least Privilege	No	All have customer data access
Disaster Recovery Plans	No	None in place
Password Policies	No	Minimal requirements
Separation of Duties	No	CEO does payroll
Firewall	Yes	Properly defined rules
IDS	No	Not implemented
Backups	No	No critical backups
Antivirus	Yes	Installed & monitored
Legacy Systems Monitoring	No	No regular schedule
Encryption	No	Not used

Password Management System	No	Not in place
Locks	Yes	Sufficient
CCTV	Yes	Functioning
Fire Detection/Prevention	Yes	Functioning

5. Compliance Assessment

PCI DSS - Non-Compliant (0/4): Only authorized users access card data - No; Secure storage - No; Encryption - No; Secure password policies - No. Risk: Fines, loss of payment processing.

GDPR - Partially Compliant (2/4): E.U. data secured - No; 72-hour breach notification plan - Yes; Data classified/inventoried - No (inventoried only); Privacy policies enforced - Yes. Risk: Up to 20M EUR or 4% turnover.

SOC 1/2 - Partially Compliant (1/4): User access policies - No; PII/SPII confidential - No; Data integrity - Yes; Data available to authorized - No. Risk: Loss of trust/contracts.

6. Recommendations (NIST CSF Aligned)

Protect: 1) Implement RBAC Least Privilege & remove excessive permissions. 2) Implement Separation of Duties - reassign payroll. 3) Deploy encryption (TLS 1.2+, AES-256) for card and PII. 4) Enforce strong password policy + enterprise password manager + MFA.
Recover: 5) Create Disaster Recovery Plan & Business Continuity Plan + 3-2-1 backups, test quarterly.
Detect/Respond: 6) Deploy IDS/IPS, tune SIEM alerts, create legacy system maintenance schedule with documentation.
Identify/Govern: 7) Complete data classification and inventory per GDPR Art.30, document processing (ROPA), conduct quarterly access reviews.